

UNIT 2

CHAPTER 1

1. Definition of Computer Fraud or Cyber Fraud

Definition

Cyber Fraud (or Computer Fraud) refers to illegal activities performed using computers, the internet, or digital devices to steal information, commit fraud, violate privacy, or perform identity theft.

Key Explanation Points (3–4 points)

- Cyber fraud uses computers as **tools** to perform crimes like data theft, financial fraud, and identity theft.
 - Attackers target sensitive information such as passwords, bank details, and personal data.
 - Cyber fraud can be carried out from anywhere in the world, making it difficult to trace.
 - Common examples include phishing scams, ransomware attacks, and data breaches.
-

Types (if applicable)

Examples given in PPT:

- Phishing Scam
 - Ransomware Attack
 - Identity Theft
 - Privacy Violation
-

Table: Examples of Cyber Frauds

Cyber Fraud	Victim	What Happened
Phishing Scam	Lloyds Bank Customers	Fake emails steal login details
Ransomware Attack	Carnival Cruise Lines	Customer data stolen, system locked

Real-life Example

A hacker sends a fake "Netflix login" email. When the user enters their credentials, the attacker steals their password and logs into the account to commit fraud. This is **phishing-based cyber fraud**.

2. Types of Cyber Attacks

Definition

A **cyber attack** is an attempt by hackers to damage, steal, or gain unauthorized access to computer systems, networks, or data.

Key Explanation Points (3–4 points)

- Cyber attacks target vulnerabilities in software, users, or networks.
 - Some attacks steal data, while others disrupt operations.
 - Attackers use malware, social engineering, or network exploitation.
 - Understanding attack types helps in building defense strategies.
-

Types (As per PPT)

1. **Malware**
 2. **Phishing**
 3. **Password Attacks**
 4. **DDoS**
 5. **Man-in-the-Middle (MitM)**
 6. **Drive-by Downloads**
 7. **Malvertising**
 8. **Rogue Software**
-

Table: Types of Cyber Attacks

Attack Type	Meaning
Malware	Malicious software that damages systems
Phishing	Tricking users to give sensitive data

Password Attack	Guessing or cracking passwords
DDoS	Flooding a server to make it unavailable
MITM	Attacker intercepts communication
Drive-by Download	Auto-download malware from infected sites
Malvertising	Ads used to spread malware
Rogue Software	Fake antivirus/malware tools

Real-life Example

A user visits an infected website → malware gets auto-downloaded → encrypts files and asks for payment.

This is a **drive-by ransomware attack**.

3. Types of Attackers

Definition

Attackers are individuals or groups who intentionally exploit computer systems, networks, or users for malicious purposes.

Key Explanation Points (3–4 points)

- Attackers have different motives: money, revenge, curiosity, or espionage.
 - Some attackers are insiders; others are external hackers.
 - Social engineering is a common method used by attackers.
 - Understanding attacker types helps in developing security policies.
-

Types (As per PPT)

1. **The Social Engineer** – Manipulates people to reveal information.
 2. **The Spread Phisher** – Mass-sends phishing emails.
 3. **The Hacker** – Technical expert exploiting vulnerabilities.
 4. **The Rogue Employee** – Insider misusing privileges.
 5. **The Ransom Artist** – Uses ransomware for money.
-

Table: Types of Attackers & Their Behavior

Attacker Type	Behavior
Social Engineer	Uses psychological tricks
Spread Phisher	Sends mass phishing emails
Hacker	Finds and exploits vulnerabilities
Rogue Employee	Misuses company access
Ransom Artist	Encrypts data & demands money

Real-life Example

An employee steals customer data and sells it on the dark web → this is a **rogue employee** attacker.

4. Characteristics of Cyber Fraud

Definition

Characteristics of cyber fraud describe common patterns or behaviors seen in digital fraud activities.

Key Explanation Points (3–4 points)

- Usually a **single event**, but can cause long-term damage.
 - Often involves **crimeware** (malicious tools) like keyloggers, trojans.
 - Exploits **system vulnerabilities** (software flaws, weak passwords).
 - Difficult to detect immediately due to stealthy operations.
-

Types (Characteristics Listed)

1. Singular or discrete event
 2. Uses crimeware (keyloggers, trojans, rootkits)
 3. Exploits vulnerabilities
 4. Often invisible to the victim initially
-

Table: Tools Used in Cyber Fraud

Crimeware	Purpose
Keylogger	Records keystrokes
Virus	Replicates & harms data
Trojan	Hidden malicious program
Rootkit	Hides attacker actions

Real-life Example

A keylogger installed on a user's laptop captures their email and bank passwords — leading to financial theft.

5. Fraud-Related Offenses

Definition

Fraud-related offenses are illegal actions that involve deception to gain money, property, data, or other benefits.

Key Explanation Points (3–4 points)

- Involves intentional misrepresentation or theft.
 - Can target individuals, companies, or governments.
 - Includes financial, intellectual property, healthcare, and consumer fraud.
 - Causes major monetary and reputational loss.
-

Types (As per PPT)

1. Financial Statement Fraud

- Overstating revenue or hiding liabilities.
- Example: **Satyam Computers (2009)**.

2. Asset Misuse

- Stealing cash, property, or company assets.

3. Theft of Intellectual Property

- Stealing trade secrets, patents, formulas.
- Example: Coca-Cola's BPA coating secret theft attempt.

4. Healthcare, Insurance & Banking Fraud

- Stealing user data, fake insurance claims, fraudulent transactions.

5. Consumer Fraud

- Telemarketing scams, phishing, identity theft.

Table: Fraud Offenses & Examples

Fraud Type	Example
Financial Statement Fraud	Satyam overstating revenue
Asset Misuse	Employee steals company cash
IP/Trade Secret Theft	Coca-Cola secret formula theft
Healthcare/Insurance Fraud	Fake insurance claims
Consumer Fraud	Phishing & identity theft

Real-life Example

A caller pretends to be from a bank and convinces a customer to share their OTP. Money gets stolen from the account — this is **consumer fraud via phishing**.

6. Encryption in Crime and Terrorism

Definition

Encryption is the process of converting readable data (plaintext) into unreadable form (ciphertext) to protect its confidentiality. Criminals misuse encryption to hide their communication and data from law enforcement.

Key Explanation Points (3–4 points)

- Criminals encrypt their communication to avoid police surveillance.
- Terrorists use encrypted messaging apps to coordinate without detection.
- Encrypted storage helps hide illegal files, money trails, or confidential information.
- Cryptography strengthens their privacy, making investigation difficult.

Types (Criminal Use of Encryption — 4 Domains)

(PPT references 4 domains; standard domains are listed below)

1. **Communication Encryption**

- Encrypted chats, emails, VoIP calls.

2. **Data Storage Encryption**

- Hard-disk encryption hides illegal files.

3. **Network Encryption**

- Using VPN/Tor to hide online activity.

4. **Device Encryption**

- Encrypted phones used to store criminal data.

Table: Criminal Use of Encryption

Domain	Example
Communication	Terrorists using WhatsApp/Signal
Storage	Encrypted USB drive holding stolen data
Network	Criminals hiding behind VPN
Device	Encrypted mobile used for planning crimes

Real-life Example

Terrorists using **Signal/Telegram** to plan attacks — police cannot read the messages due to end-to-end encryption.

7. Law Enforcement Options

Definition

Law enforcement uses various strategies to bypass or defeat encryption during criminal investigations.

Key Explanation Points (3–4 points)

- Encryption does **not completely block investigations**.
- Police often obtain encryption keys from suspects, devices, or third parties.
- Investigators may break weak encryption using tools or flaws.

- They may also find ways to access systems before encryption is applied.

Types (Law Enforcement Options)

1. **Getting Key from Subject**
 - Suspect voluntarily gives password or key.
2. **Access Through a Third Party**
 - Cloud providers, ISPs, or companies give access.
3. **Breaking the Codes**
 - Using technical tools to crack weak encryption.
4. **Finding an Access Point**
 - Getting data before encryption (e.g., keyloggers).
5. **When All Else Fails: Brute Force Attack**
 - Trying all possible keys until one works.

Table: Law Enforcement Options & Methods

Method	How It Works
Getting Key	Asking suspect or through legal order
Third Party Access	Cloud backup reveals data
Breaking Codes	Cracking weak encryption
Access Point	Getting data before encryption
Brute Force	Trying billions of passwords

Real-life Example

In many cases, police unlock suspects' phones by accessing **cloud backups**, even when the device is encrypted.

8. Technologies for Hiding Evidence

Definition

Criminals use digital tools and methods to hide illegal data, activities, or identities to avoid detection by law enforcement.

Key Explanation Points (3–4 points)

- These methods help criminals hide sensitive files or communications.
 - They make it difficult for investigators to trace the origin of crimes.
 - Often used with encryption for stronger security.
 - Tools include passwords, compression, steganography, and remote storage.
-

Types (Technologies for Hiding Evidence)

1. Passwords

- Used to secure access to devices or files.
- PINs, strong passwords, biometrics.

2. Digital Compression

- Data is compressed to reduce size and make it harder to recognize.

3. Steganography

- Hiding secret data inside images, audio, or videos.

4. Remote Storage

- Data stored on remote servers (ISPs/cloud) to avoid local seizure.
-

Table: Hiding Evidence Techniques

Technique	Purpose
Password	Prevents unauthorized access
Digital Compression	Makes data smaller & harder to detect
Steganography	Hides data inside media files
Remote Storage	Keeps data away from local devices

Real-life Example

A criminal hides a secret message inside a JPEG image using steganography — even forensic investigators may initially miss it.

9. Concealing Crimes Through Anonymity

Definition

Anonymity tools allow users to hide their identity online, making it difficult for authorities to trace criminal activities.

Key Explanation Points (3–4 points)

- Criminals hide behind anonymous networks to avoid being tracked.
- Anonymous tools remove identifiers like IP address or phone number.
- Used to commit fraud, cyberbullying, drug trafficking, or cyber attacks.
- Law enforcement faces challenges linking actions to individuals.

Types (Technologies Used for Anonymity)

1. Anonymous Remailers

- Send emails without revealing sender identity.

2. Anonymous Digital Cash

- Use cryptocurrency wallets for anonymous payments.

3. Cellular Phone Cloning

- Duplicate mobile device identity to hide caller.

4. Mobile SIM Cards (Burner SIMs)

- Temporary SIM cards used once and discarded.

Table: Anonymity Tools and Purposes

Tool	Purpose
Anonymous Remailers	Hide sender identity
Digital Cash	Anonymous online payments
Phone Cloning	Hide caller identity
Temporary SIM	Avoid traceability

Real-life Example

Drug dealers on the dark web use **Bitcoin** for payments and **Tor email services** to stay anonymous — making it almost impossible to trace them.

22BA170729 - UNIT 2

CHAPTER 2

1. Evaluation Criteria and Security Testing

Definition

Evaluation criteria and security testing refer to the standards and processes used to ensure an application is **secure**, free of vulnerabilities, and meets all required security controls during development.

Key Explanation Points (3–4 points)

- Developers must follow security evaluation criteria to ensure safe, reliable software.
 - Security testing identifies bugs, loopholes, and vulnerabilities before release.
 - Ensures applications remain protected from internal and external threats.
 - Helps maintain confidentiality, integrity, and availability of data.
-

Types (Evaluation Criteria)

As per PPT, the evaluation process includes:

1. **Automation** – Use automated tools for testing.
 2. **Usability** – Application must be easy to use securely.
 3. **SUT (Software Under Test) Requirements** – Tested based on given requirements.
 4. **Platform** – OS, hardware, and environment must be considered.
 5. **Authentication** – Proper login & identity verification.
 6. **Session Handling** – Secure management of user sessions.
-

Table: Security Evaluation Criteria

Criteria	Purpose
Automation	Faster, consistent testing
Usability	Secure and user-friendly
Requirements (SUT)	Tests match application needs
Platform	Ensures compatibility & security
Authentication	Prevents unauthorized access

Session Handling	Stops session hijacking
------------------	-------------------------

Types of Security Testing

1. **Vulnerability Scanning**
 2. **Security Scanning**
 3. **Penetration Testing**
 4. **Risk Assessment**
 5. **Security Auditing / Review**
 6. **Ethical Hacking**
-

Real-life Example

Before releasing a banking mobile app, the company performs **penetration testing** to ensure hackers cannot bypass authentication or steal user data.

2. International Standard

Definition

International standards are globally accepted rules, guidelines, or specifications that ensure products, processes, and services meet quality, security, and compliance requirements.

Key Explanation Points (3–4 points)

- Provide uniform criteria across countries and organizations.
 - Help ensure product safety, interoperability, and security.
 - Make global business easier by removing regional differences.
 - ISO standards related to security ensure the protection of data.
-

Types (Key ISO Standards in PPT)

ISO 27001 (ISMS)

- Focus: Information Security Management System
- Ensures data is: **Correct, Accurate, Available, Accessible only to approved employees**

ISO 27701 (PIMS)

- Focus: Privacy Information Management System
- Ensures: **Proper handling, collecting, storing, and protecting personal data**

Table: ISO 27001 vs ISO 27701

Feature	ISO 27001	ISO 27701
Focus	Security (ISMS)	Privacy (PIMS)
Purpose	Protect information accuracy & availability	Protect personal data & avoid misuse
Applies To	All organizational data	Only personal data processing
Objective	Correctness & security	Privacy protection

Real-life Example

A hospital adopting **ISO 27701** ensures patient medical data is handled privately and not shared without consent, while **ISO 27001** ensures the data stays accurate and secure.

3. Analysis and Logging

A. Analysis

Definition

Analysis is the detailed examination of a system or process to understand its behavior, identify weaknesses, and verify that it meets intended security requirements.

Key Explanation Points (3–4 points)

- Helps detect vulnerabilities early before implementation.
 - Supports decision-making based on risk assessments and threat models.
 - Defines risk tolerance levels for security planning.
 - Ensures design improves after identifying threats.
-

Types (if applicable)

Not types, but **steps** include:

- Threat analysis
 - Attack surface reduction
 - Risk tolerance setting
 - Design improvement
-

Table: Analysis Activities

Activity	Purpose
Risk Assessment	Identify threats
Vulnerability Detection	Find weaknesses
Attack Surface Review	Reduce exposure
Scenario Evaluation	Improve design

Real-life Example

Before building an online payment system, developers analyze threats like MITM attacks, SQL injection, and weak session management, then update the design accordingly.

B. Logging (Log Management)

Definition

Log management involves collecting, storing, and analyzing system logs to monitor user activities and detect suspicious or malicious behavior.

Key Explanation Points (3–4 points)

- Logs help trace actions of users and attackers.
 - Security logging records all activities for investigations.
 - Data protection laws require protecting user privacy even in logs.
 - Advanced logging helps identify intrusions and risky behavior.
-

Types (Aspects of Logging)

1. **Collection** – Gathering logs
2. **Storage** – Secure retention
3. **Evaluation** – Analysis for anomalies

Table: Logging Conflict Areas

Need	Explanation
Security	Requires detailed logs for long periods
Privacy	Requires limiting what user data is stored

Real-life Example

A bank keeps login and transaction logs for fraud detection but hides personal details to protect customer privacy.

4. Security Policy Development

Definition

Security policy development is the creation and maintenance of documented security rules that protect sensitive data, systems, and organizational interests.

Key Explanation Points (3–4 points)

- Forms the foundation of an organization's security program.
- Ensures compliance with legal, ethical, and organizational requirements.
- Defines roles, responsibilities, and security objectives.
- Protects sensitive information and critical systems.

Types (Policy Development Factors)

1. Identify sensitive information & critical systems
2. Follow local, state, federal laws
3. Define institutional goals & objectives
4. Create a roadmap to achieve these objectives
5. Ensure mechanisms/tools exist to enforce policies

Table: Policy Development Steps

Step	Purpose
Identify Assets	Know what to protect
Follow Laws	Maintain compliance
Set Goals	Drive the purpose
Implement Controls	Apply security mechanisms
Review	Ensure policy effectiveness

Real-life Example

A university creates a **data privacy policy** ensuring student academic records are stored securely and accessed only by authorized staff.

5. Framework and Security Standards

Definition

Security standards are formal guidelines defining how systems should protect data, while security frameworks are structured methodologies used to implement and manage security controls.

Key Explanation Points (3–4 points)

- Provide consistent security structure for organizations.
 - Ensure systems maintain confidentiality, integrity, and availability.
 - Required for compliance with industry regulations.
 - Integrated into Software Development Lifecycle (SDLC) for secure development.
-

Types (Two Categories)

1. **Security Standards**
 2. **Security Frameworks**
-

Table: Standards vs Frameworks

Aspect	Security Standards	Security Frameworks
Purpose	Specific rules	Step-by-step approach
Example	ISO 27001	NIST CSF
Usage	Compliance	Implementation

Real-life Example

A bank uses **ISO 27001** for compliance and **NIST CSF** as a strategic framework to manage cybersecurity risks.

6. Prominent Security Standards

Definition

Prominent security standards are globally accepted guidelines that organizations follow to maintain strong information security practices.

Key Explanation Points (3–4 points)

- Provide consistent, internationally approved security rules.
 - Help ensure systems meet legal, business, and regulatory requirements.
 - Reduce security risks through structured controls.
 - Help organizations demonstrate trustworthiness.
-

Types (as per PPT)

1. **ISO/IEC 27001** – Requirements for ISMS
 2. **ISO/IEC 27002** – Security control guidelines
 3. **ISO/IEC 27005** – Risk management guidance
 4. **IEC 62443** – Industrial control system security
 5. **CIS Controls** – Prioritized best practices
-

Table: Prominent Standards Summary

Standard	Focus
----------	-------

ISO 27001	ISMS requirements
ISO 27002	Security control practices
ISO 27005	Risk management
IEC 62443	Industrial systems
CIS Controls	Practical cybersecurity rules

Real-life Example

Factories use **IEC 62443** to protect industrial control systems from cyberattacks on machinery and robotics.

7. Key Security Frameworks

Definition

Security frameworks are structured models that guide organizations in managing, preventing, and responding to cybersecurity risks.

Key Explanation Points (3–4 points)

- Provide guidance on security policies and procedures.
 - Help organizations protect against, detect, and respond to threats.
 - Used for compliance, governance, and risk management.
 - Commonly adopted by government, private, and cloud organizations.
-

Types (as per PPT)

1. **NIST Cybersecurity Framework (CSF)**
 2. **NIST SP 800-53**
 3. **NIST SP 800-171**
 4. **COBIT**
 5. **CSA Cloud Controls Matrix (CCM)**
-

Table: Key Framework Overview

Framework	Purpose
NIST CSF	Cybersecurity guidance for private sector
NIST 800-53	Security & privacy controls
NIST 800-171	Protect CUI data
COBIT	IT governance & management
CSA CCM	Cloud security controls

Real-life Example

Cloud service providers like AWS and Azure use **CSA CCM** to ensure secure cloud services.

8. Core Components of Frameworks

Definition

Core components refer to fundamental elements required for implementing any security framework.

Key Explanation Points (3–4 points)

- Frameworks rely on risk management as their foundation.
 - Controls are applied to mitigate identified risks.
 - Continuous monitoring ensures effectiveness.
 - Improvement ensures defenses stay updated to new threats.
-

Types (Core Components)

1. Risk Assessment
 2. Control Implementation
 3. Monitoring & Review
 4. Continuous Improvement
-

Table: Components & Functions

Component	Function
-----------	----------

Risk Assessment	Identify threats & vulnerabilities
Control Implementation	Apply security controls
Monitoring	Evaluate control effectiveness
Continuous Improvement	Update controls over time

Real-life Example

A company monitors logs for suspicious activity daily (Monitoring) and updates firewalls monthly (Continuous Improvement).

9. Mapping and Integration

Definition

Mapping and integration involve aligning multiple security standards and frameworks to create a **unified security strategy**.

Key Explanation Points (3–4 points)

- Ensures no security requirement is missed.
 - Helps organizations comply with multiple standards simultaneously.
 - Uses "crosswalks" to map controls from one framework to another.
 - Reduces duplication of effort and increases consistency.
-

Types (Mapping Examples)

- Mapping NIST CSF with ISO 27001
 - Mapping CSA CCM with NIST 800-53
 - Mapping CIS Controls to ISO 27002
-

Table: Mapping Examples

Standard A	Mapped To	Purpose
ISO 27001	NIST CSF	Unified security
NIST 800-53	CSA CCM	Cloud security alignment

Real-life Example

A company using both ISO 27001 and NIST CSF maps their controls to ensure they meet both standards without duplicate work.

10. Application in SDPL (Secure Development Process Lifecycle)

Definition

Applying security in SDPL means integrating security activities at every stage of software development to ensure secure, reliable applications.

Key Explanation Points (3–4 points)

- Security is added from the **design phase**, not after development.
 - Prevents vulnerabilities by using secure coding practices.
 - Uses testing methods like static/dynamic analysis.
 - Ensures secure deployment and continuous monitoring.
-

Types (Security Areas in SDPL)

1. **Secure Design Principles**
 2. **Secure Coding Practices**
 3. **Security Testing**
 4. **Deployment & Maintenance**
-

Table: SDPL Security Activities

Stage	Security Focus
Design	Threat modeling
Coding	Secure coding standards
Testing	Static/dynamic testing
Deployment	Secure configurations
Maintenance	Patch management

Real-life Example

In a fintech app, developers use **input validation**, **secure APIs**, and **penetration testing** before deployment to avoid fraud and data theft.

22BA170729 - UNIT 2

CHAPTER 3

1. Framework

Definition

A **cybersecurity framework** is a structured guideline to help organizations manage and reduce cybersecurity risks. It integrates cybersecurity into the overall **risk management strategy**, similar to financial, operational, and reputational risks.

Key Explanation Points (3–4 points)

- Cybersecurity threats exploit the **complexity** and **connectivity** of modern systems like power grids, transportation, healthcare, etc.
 - Damage from cyber threats affects **revenue, customer trust, innovation, and company reputation**.
 - Frameworks help organizations manage cybersecurity risks in a systematic and repeatable way.
 - They ensure that every level of the organization understands their role in security.
-

Types (Framework Implementation Levels)

Implementation is done by **3 levels of people**:

1. Executive Level

- Sets overall security direction
- Approves budgets & policies
- Aligns security with business goals

2. Business / Process Level

- Converts executive policies into actionable processes
- Defines procedures, workflows, and rules

3. Implementation / Operations Level

- Performs technical tasks
 - Monitors systems, detects threats, applies patches
 - Handles day-to-day security operations
-

Table: Framework Implementation Responsibilities

Level	Role in Framework	Key Responsibilities
Executive	Strategic	Approves cybersecurity goals, allocates resources
Business/Process	Tactical	Designs processes, assigns responsibilities
Operations	Technical	Implements security controls, monitors threats

Real-life Example

A hospital adopts a cybersecurity framework to protect patient records:

- **Executives** approve security budget and policies.
- **Process managers** define rules for accessing medical records.
- **IT operations team** installs firewalls, monitors logs, and detects breaches.

This ensures security at all organizational layers.

2. Security Standards

Definition

A **security standard** is a published technical guideline that organizations follow to ensure consistent, secure, and reliable IT systems. Standards define rules, methods, controls, and frameworks to protect information and reduce cybersecurity risks.

Key Explanation Points (3–4 points)

- Standards improve **efficiency**, **interoperability**, and **comparability** across organizations.
- They reduce complexity by providing **uniform security rules**.
- They cover methods, guidelines, controls, and reference frameworks.
- The aim is to protect IT systems, networks, and critical sectors like finance, healthcare, energy, etc.

Types (Based on PPT)

A. ISO (International Organization for Standardization)

- Established: **23 Feb 1947**
- Independent, non-government, global organization

ISO 27000 Series

A family of international security standards that provide a framework for **Information Security Management**.

Includes:

- **ISO 27001** – Information Security Management System (ISMS)
 - **ISO 27002** – Best practices / security controls
 - **ISO 27005** – Risk management
 - **ISO 27032** – Cybersecurity guidelines
-

B. IT Act 2000 (India)

- India's main cyber law
 - Deals with hacking, fraud, data crimes, e-commerce, digital signatures
 - Based on the **UN Model Law on E-Commerce, 1996**
-

C. Other Legal Standards

- **Copyright Act** – Protects creative works (software, code, designs)
 - **Patent Law** – Protects inventions
 - **Intellectual Property Rights (IPR)** – Protects ownership of ideas and technology
-

Table: Major Security Standards & Purpose

Standard / Law	Purpose
ISO 27001	Creates an Information Security Management System (ISMS)
ISO 27002	Provides guidance on security controls
ISO 27005	Focuses on risk management
ISO 27032	Deals with cybersecurity
IT Act 2000	Cybercrime regulation and e-commerce legality
Copyright Act	Protects software / creative content
Patent Law	Protects technological inventions
IPR	Protects ownership of innovations

Real-life Example

A software company handling user data must:

- Follow **ISO 27001** to secure customer data.
 - Follow **IT Act 2000** to handle cybercrime incidents involving Indian citizens.
 - Use **Copyright Act** to protect its source code.
 - Use **Patent Law** to protect newly invented algorithms.
-

3. How Security Certifications Are Developed?

Definition

Security certifications are developed through a formal process where international bodies (like ISO) define standards, convert them into documented controls, and create certification systems that organizations must follow and pass through audits.

Key Explanation Points (3–4 points)

- Certifications ensure organizations follow globally accepted **security best practices**.
 - Developed by combining expert knowledge, industry needs, and risk management principles.
 - Certification bodies test organizations through **audits and assessments**.
 - Ensures consistency, trust, and measurable security across the world.
-

Types (Stages of Certification Development)

1. Requirement Collection

- Experts collect global security needs and risks.

2. Standard Creation

- Requirements are converted into documented rules.

3. Accredited Certification Bodies

- Organizations like ISO authorize auditors.

4. Auditing & Testing

- Companies undergo process audits.

5. Certification Issued

- Granted if standards are met.

6. Continuous Monitoring

- Yearly review audits ensure ongoing compliance.

Table: Certification Development Lifecycle

Stage	Description
Requirements	Identify global security needs
Drafting	Documents are written by expert committees
Standard Release	Published internationally
Auditing	Independent bodies assess compliance
Certification	Issued to organizations
Surveillance Audit	Annual check for maintenance

Real-life Example

A cloud company undergoes an **ISO 27001 audit** where auditors check risk assessments, policies, controls, and logs. If requirements are met, certification is granted.

4. Security Certification (ISO 17799 / ISO 27001)

Definition

ISO 17799 and ISO 27001 are internationally recognized standards for information security management. They protect the **confidentiality, integrity, and availability** of information.

Key Explanation Points (3–4 points)

- Both are derived from **BS 7799**, a British security standard.
 - ISO 17799 gives **best practice guidance** for managing information security.
 - ISO 27001 gives **formal requirements** for creating an ISMS and obtaining certification.
 - Information security laws use these standards because **information has value**.
-

Types (Two Main Standards)

A. ISO 17799 (BS 7799 Part 1)

- Best practice recommendations
- Non-certifiable
- Focuses on guidelines and controls

B. ISO 27001 (BS 7799 Part 2)

- Certifiable standard
- Specifies ISMS requirements
- Focuses on implementation, monitoring, and improvement

Table: ISO 17799 vs ISO 27001

Feature	ISO 17799	ISO 27001
Origin	BS 7799:1	BS 7799:2
Purpose	Guidelines & best practices	Certification requirements
Certifiable?	No	Yes
Focus	Initiation & Implementation guidance	ISMS establishment & audit

Real-life Example

A software company uses **ISO 17799** guidelines for internal security and seeks **ISO 27001 certification** to prove data security compliance to clients.

5. SSE-CMM (System Security Engineering Capability Maturity Model)

Definition

SSE-CMM describes the essential characteristics of an organization's security engineering processes and measures how mature, consistent, and effective they are.

Key Explanation Points (3–4 points)

- Helps organizations evaluate how well they perform **security engineering**.
- Measures maturity from basic to optimized levels.
- Used heavily in large IT, defense, and critical infrastructure projects.

- Provides a roadmap for continuous improvement.

Types (5 Maturity Levels)

1. **Performed Informally (Level 1)**
 - Basic processes exist but not standardized.
2. **Planned and Tracked (Level 2)**
 - Processes are documented and tracked.
3. **Well-Defined (Level 3)**
 - Standardized across the organization.
4. **Quantitatively Controlled (Level 4)**
 - Performance measured using metrics.
5. **Continuously Improving (Level 5)**
 - Processes optimized and regularly improved.

Table: SSE-CMM Process Areas (as per your image)

No.	Process
1	Administer Security Controls
2	Assess Impact
3	Assess Security Risk
4	Assess Threat
5	Assess Vulnerability
6	Build Assurance Argument
7	Coordinate Security
8	Monitor System Security Posture
9	Provide Security Input
10	Specify Security Needs
11	Verify & Validate Security

Real-life Example

A cybersecurity firm reaches **Level 5**, meaning all processes are measured, optimized, and continuously improved based on threat intelligence.

6. Information Security

Definition

Information security is the practice of protecting information from unauthorized access, disclosure, alteration, destruction, or disruption.

Key Explanation Points (3–4 points)

- Protects the confidentiality, integrity, and availability (CIA) of data.
 - Requires legal frameworks, standards, and controls.
 - Ensures compliance with security laws and regulations.
 - Necessary because **information has economic value**.
-

Types (Major Laws & Standards)

1. PCI-DSS

- Protects credit/debit card information.

2. ISO 27001:2013

- International ISMS standard for security controls.

3. HIPAA

- Protects patient health data in the US.

4. DMCA

- Protects digital copyrights.

5. IT Act 2000

- India’s primary cyber law.
-

Table: Information Security Laws & Purpose

Law/Standard	Focus
PCI-DSS	Cardholder data security

ISO 27001	Global ISMS framework
HIPAA	Patient data protection
DMCA	Copyright protection
IT Act 2000	Indian cybercrime & e-commerce regulation

Real-life Example

A hospital must follow **HIPAA** to protect patient medical records from being shared without consent.

7. Legal Framework for Information Security

Definition

A legal framework for information security defines the regulatory steps organizations must take to protect data and comply with laws.

Key Explanation Points (3–4 points)

- Ensures all security activities follow legal standards.
 - Aligns with NIST's Identify → Protect → Detect → Respond → Recover cycle.
 - Prevents legal penalties and data breaches.
 - Supports trusted and secure operations.
-

Types (Steps in Legal Framework)

1. **Identify Risks**
 2. **Identify Safeguards**
 3. **Create Safeguards**
 4. **Verify Safeguards**
 5. **Update Safeguards**
-

Table: Legal Security Steps

Step	Description
------	-------------

Identify Risks	Find potential threats
Identify Safeguards	Choose controls to stop threats
Create Safeguards	Implement controls
Verify Safeguards	Test effectiveness
Update Safeguards	Improve over time

Real-life Example

A bank identifies risks (phishing, ATM skimming), creates safeguards (encryption, OTP), and verifies them through audits to comply with RBI guidelines.

8. Recovery and Risk Analysis

1. Definition

Recovery Risk is the risk that after a default or crisis, an organization may not be able to fulfil obligations, leading to financial loss.

Risk Analysis is the process of identifying, analyzing, and evaluating risks to minimize damage during security incidents.

2. Key Explanation Points (3–4 points)

- Recovery planning ensures that after a disaster (cyberattack, system failure), business operations resume quickly.
 - Helps reduce financial loss, downtime, and damage to reputation.
 - Risk analysis helps identify *where* the system is weak and *how* threats can exploit those weaknesses.
 - A structured recovery plan makes organizations resilient and prepared for crises.
-

3. Types (Three Steps of Risk Assessment)

1. Risk Identification

- Identify assets, threats, vulnerabilities, and potential failure points.

2. Risk Analysis

- Understand how likely a risk is and how severe its impact could be.

3. Risk Evaluation

- Compare risks against acceptable limits and decide which risks need action.

4. Table: Risk Assessment Breakdown

Step	Meaning	Example
Risk Identification	Find threats & vulnerabilities	Outdated software → Malware risk
Risk Analysis	Assess likelihood & impact	High risk of data breach
Risk Evaluation	Decide if risk is acceptable	Risk is high → must patch system

5. Real-life Example

A bank suffers a ransomware attack:

- **Risk Identification:** Detect malware and identify compromised servers.
- **Risk Analysis:** Analyze impact – customer data unavailable, operations halted.
- **Risk Evaluation:** Decide critical systems must be restored within 2 hours.
- **Recovery Plan:** Restore from backups, isolate infected systems, resume critical services.

This minimizes losses and downtime.

9. Operating System and Application Specific Auditing

1. Definition

Operating system and application auditing involves collecting detailed logs of all security-related events to detect misuse, analyze incidents, and improve system security.

2. Key Explanation Points (3–4 points)

- Modern OS and applications create **audit logs** that record every important activity (login attempts, file access, configuration changes).
 - These logs help detect **security attacks** such as unauthorized access or malware infections.
 - Auditing helps improve policies and track user behaviour.
 - Comprehensive auditing can be expensive and time-consuming, especially for large systems.
-

3. Types (Audit Areas)

1. Operating System Audit

- Records login attempts, file access, privilege changes, system errors, etc.

2. Application Audit

- Verifies whether application transactions and outputs are accurate, valid, and secure.

4. Table: OS Audit vs Application Audit

Feature	OS-Specific Audit	Application-Specific Audit
Focus	System-level actions	Transactions & data accuracy
Example Logs	Login attempts, file access	Financial transactions, user actions
Goal	Detect misuse of system resources	Ensure app data accuracy and security
Difficulty	Moderate	High (many apps → costly)

5. Real-life Example

A bank’s transaction application undergoes an **Application Control Audit**:

- Auditors check whether deposits, withdrawals, and transfers are logged accurately.
- Incorrect or unauthorized transactions are flagged as security incidents.
- OS logs help identify who logged in, when, and what commands were executed.

This helps the bank maintain security, compliance, and trust.